

CYBERSECURITY 266IT

Report Esercitazione di Malware Analysis

S9 L3

Andrea Calabretta

1. Introduzione alla Malware Analysis	3
1.1. Introduzione.....	3
2. Workflow Operativo	4
2.1. Introduzione.....	4
2.2. Submission del Campione su Triage	4
2.3. Analisi Statica su Triage	5
2.4. Risultati dell'Analisi Dinamica	5
2.5. Trasferimento del Report da FlareVM a Kali Linux	6
2.6. Download del Report su Kali Linux.....	7
2.7. Visualizzazione del Report su Kali Linux.....	8
3. Analisi RCIF-D — WannaCryptor.....	8
3.1. Introduzione.....	8
3.2. Famiglia Malware	8
3.3. Tecniche MITRE ATT&CK.....	9
3.4. IoC Principali	10
3.5. Remediation (Blue Team / SOC).....	10
4.0 Sintesi Esecutiva	11

1. Introduzione alla Malware Analysis

1.1. Introduzione

La malware analysis è una disciplina fondamentale della cybersecurity che consiste nell'esame sistematico di software malevolo al fine di comprenderne il comportamento, l'impatto e le tecniche di attacco. Nell'ambito delle attività di un SOC Analyst o di un professionista Blue Team, saper analizzare un campione di malware consente di identificare rapidamente gli indicatori di compromissione (IoC), mappare le tecniche MITRE ATT&CK utilizzate dall'attaccante e sviluppare contromisure efficaci.

In questo report descrivo il percorso di analisi condotto su un campione di WannaCryptor, il famoso ransomworm che nel maggio 2017 colpì centinaia di migliaia di sistemi in tutto il mondo sfruttando la vulnerabilità EternalBlue (MS17-010). L'analisi è stata svolta attraverso una pipeline completa: dalla submission del campione sulla piattaforma di sandbox Triage (Recorded Future), al trasferimento del report verso il sistema di analisi su Kali Linux, fino all'interpretazione automatizzata tramite intelligenza artificiale (Claude) con il framework RCIF-D.

Il framework RCIF-D (Ruolo, Contesto, Istruzione, Formato, Disclaimer) è una tecnica di prompt engineering che permette di strutturare le richieste a un LLM in modo da ottenere output precisi, affidabili e contestualizzati, ideale per analisi di threat intelligence.

2. Workflow Operativo

2.1. Introduzione

Di seguito descrivo in ordine cronologico le fasi operative che ho seguito per analizzare il campione WannaCryptor, dalla submission su Triage fino all'interpretazione del report con Claude Sonnet 4.6.

2.2. Submission del Campione su Triage

Ho avviato l'analisi caricando il campione WannaCrypt0r.exe (contenuto in un archivio ZIP protetto da password) sulla piattaforma Triage di Recorded Future. Ho configurato la submission con i seguenti parametri:

- Target: WannaCrypt0r.exe (estratto dall'archivio WannaCrypt0r.exe.zip, 3.5 MB)
- Password archivio: infected
- Piattaforme selezionate: Windows 10-2004 x64, Windows 11-21H2 x64
- Timeout analisi: 10 minuti
- Lingua sistema: en-us



Figura 1 — Schermata di submission su Triage con configurazione parametri di analisi

2.3. Analisi Statica su Triage

Prima dell'esecuzione dinamica, Triage ha effettuato un'analisi statica del binario, rilevando le caratteristiche del file e assegnando un punteggio preliminare di 3/10. L'analisi statica ha identificato la natura del file (eseguibile PE32 per architettura x64/x86) e ha estratto i metadati fondamentali come SHA256, dimensione e tag comportamentali attesi.

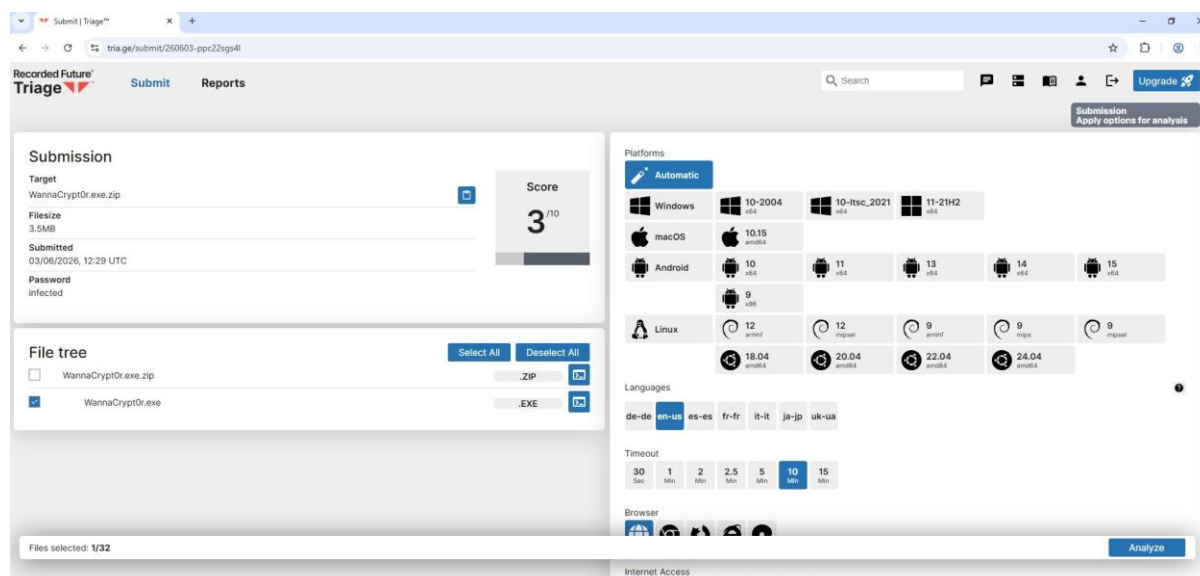


Figura 2 — Risultati dell'analisi statica su Triage: score iniziale 3/10 e configurazione piattaforme

2.4. Risultati dell'Analisi Dinamica

Al termine dei 10 minuti di sandbox, il sistema ha restituito un punteggio finale di 10/10, il massimo sulla scala di Triage. Il report dinamico ha confermato la famiglia WannaCry con una serie di tag comportamentali critici: RANSOMWARE, WORM, STEALER, SPYWARE, DEFENSE_EVASION, EXECUTION, PERSISTENCE, IMPACT, SURICATA.

I dati principali estratti dal report dinamico sono i seguenti:

Campo	Valore
Target	WannaCrypt0r.exe
Dimensione	3.4 MB
Sample ID	260603-ppc22sgs4l
SHA256	ed01ebfbc9eb5bbea545af4d01bf5f1071661840480439c6e5babe8e080e41aa
Score Triage	10/10
Platform	windows10-2004-x64
Ransom note path	C:\Users\Admin\AppData\Local\Temp\@Please_Read_Me@.txt
Mutex	wannacry

The screenshot displays the Triage interface for a malware analysis. The top navigation bar includes 'Submit' and 'Reports' tabs. The main content area is divided into several sections:

- General:**
 - Target: WannaCrypt0r.exe
 - Size: 3.4MB
 - Sample: 260603-ppc22sgs4l
 - SHA256: ed01ebfbc9eb5bbea545af4d0b1f51071661840480439c6e5babe8e080e41aa
- Score:** 10/10
- Behavioral Tags:** WANNACRY, DISCOVERY, EXECUTION, IMPACT, PERSISTENCE, RANSOMWARE, SPYWARE, STEALER, SURICATA, WORM.
- Malware Config:**
 - Extracted Path: C:\Users\Admin\AppData\Local\Temp\Please_Read_Me@.txt
 - Wannacry

Figura 3 — Report dinamico su Triage: score 10/10, tag comportamentali e Malware Config estratta

2.5. Trasferimento del Report da FlareVM a Kali Linux

Una volta completata l'analisi, ho esportato il report dalla piattaforma Triage in formato PDF tramite la funzione "Print to PDF" del browser. Il file è stato salvato nella cartella Report WannaCryptor sul Desktop della macchina virtuale FlareVM (Windows 10).

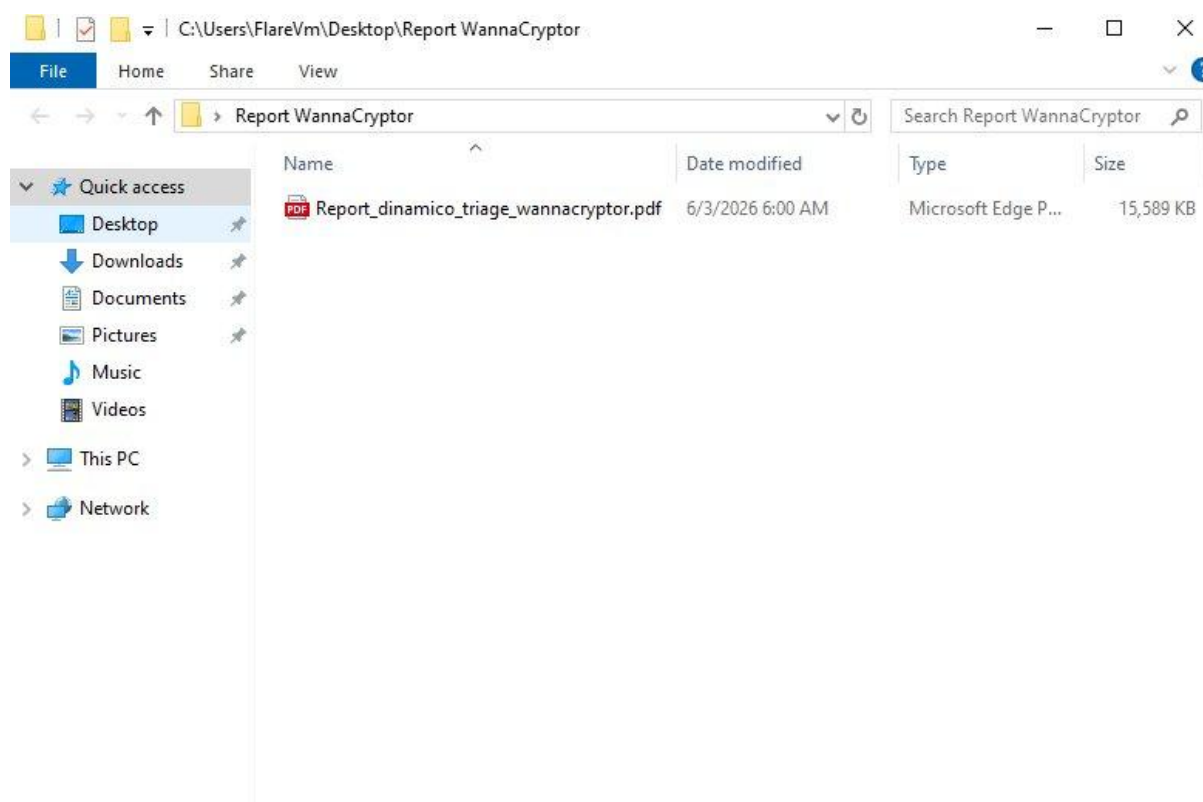


Figura 4 — Cartella Report WannaCryptor su FlareVM con il PDF esportato (15.589 KB)

Per trasferire il file alla macchina Kali Linux ho avviato un server HTTP temporaneo con Python direttamente dalla cartella contenente il PDF:

```
python -m http.server
```

Questo comando ha esposto il file sulla porta 8000 dell'IP della macchina FlareVM (192.168.50.150).

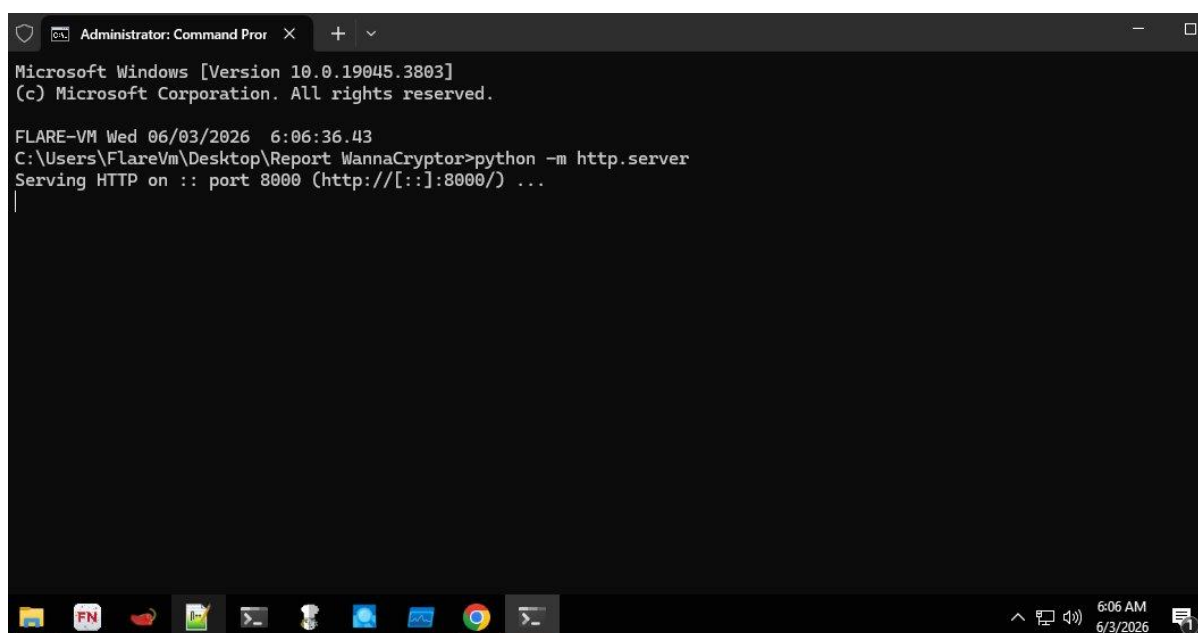


Figura 5 — Server HTTP Python avviato su FlareVM sulla porta 8000 per il trasferimento del PDF

2.6. Download del Report su Kali Linux

Dal browser di Kali Linux ho navigato all'indirizzo <http://192.168.50.150:8000> e ho scaricato il file Report_dinamico_triage_wannacryptor.pdf, che è comparso nella directory listing servita da Python.

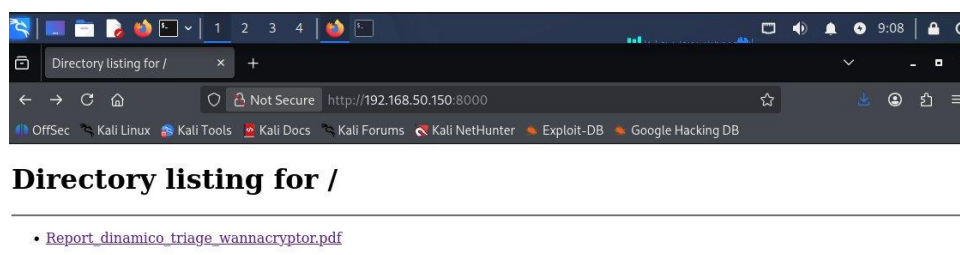


Figura 6 — Directory listing del server HTTP su Kali Linux: file PDF disponibile per il download

2.7. Visualizzazione del Report su Kali Linux

Una volta scaricato, ho aperto il report PDF su Kali Linux verificando la corretta ricezione del documento (41 pagine). Il report completo di Recorded Future Sandbox include cover page, indice, matrice MITRE ATT&CK, log di processo, traffico di rete e configurazione malware estratta.

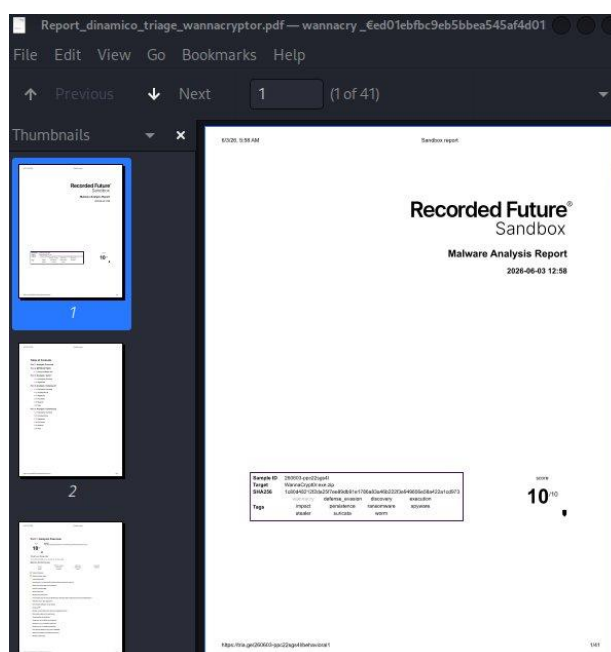


Figura 7 — Report PDF aperto su Kali Linux (41 pagine) — Recorded Future Sandbox Malware Analysis Report

3. Analisi RCIF-D — WannaCryptor

3.1. Introduzione

Ho sottoposto il report JSON estratto dalla piattaforma Triage a Claude utilizzando il framework RCIF-D, strutturando il prompt con: Ruolo (malware analyst senior), Contesto (campione analizzato su Triage), Istruzione (identificare famiglia, MITRE ATT&CK, IoC e remediation), Formato (tabelle Markdown) e Disclaimer (basarsi solo sui dati forniti). Di seguito presento i risultati dell'analisi organizzati nelle quattro categorie richieste.

3.2. Famiglia Malware

Campo	Valore
Nome	WannaCry / WannaCrypt0r
Tipo	Ransomworm (Ransomware + Worm)
Score Triage	10/10
SHA256	ed01ebfbc9eb5bbea545af4d01bf5f1071661840480439c6e5babe8e080e41aa
Dimensione	3.4 MB

Campo	Valore
Platform	Windows 10 x64
Tag comportamentali	WANNACRY, RANSOMWARE, WORM, STEALER, SPYWARE, SURICATA
Anno comparsa	2017 (campagna globale maggio 2017)
Vettore iniziale	Exploit EternalBlue (MS17-010) via SMB porta 445

3.3. Tecniche MITRE ATT&CK

ID Tecnica	Nome	Descrizione
T1047	Windows Management Instrumentation	Esecuzione comandi tramite WMI
T1547	Boot or Logon Autostart Execution	Persistenza al riavvio del sistema
T1547.001	Registry Run Keys	Chiavi di registro per autostart
T1222	File and Directory Permissions Modification	Modifica permessi file/cartelle
T1222.001	Windows File and Dir. Permissions	Specifico per sistemi Windows
T1564	Hide Artifacts	Nasconde artefatti sul sistema
T1564.001	Hidden Files and Directories	Crea file e cartelle nascosti
T1070	Indicator Removal	Rimozione delle tracce di compromissione
T1070.004	File Deletion	Cancellazione file post-cifratura
T1112	Modify Registry	Modifica chiavi del registro di sistema
T1555	Credentials from Password Stores	Furto credenziali da store
T1555.003	Credentials from Web Browsers	Estrazione credenziali da browser
T1552	Unsecured Credentials	Ricerca credenziali in chiaro
T1552.001	Credentials in Files	Credenziali salvate su file system
T1082	System Information Discovery	Raccolta informazioni di sistema
T1614	System Location Discovery	Rilevamento lingua/paese (evita CIS)
T1614.001	System Language Discovery	Controllo lingua del sistema operativo
T1005	Data from Local System	Raccolta dati dal sistema locale
T1491	Defacement	Modifica file utente (ransom note)
T1490	Inhibit System Recovery	Disabilita Shadow Copy e recovery

3.4. IoC Principali

Tipo	Valore
SHA256	ed01ebfbc9eb5bbea545af4d01bf5f1071661840480439c6e5babe8e080e41aa
Sample ID	260603-ppc22sgs4l
Ransom note path	C:\Users\Admin\AppData\Local\Temp\@Please_Read_Me@.txt
Mutex	wannacry
Killswitch domain	www.iuqerfsodp9ifjaposdfjhgosurijfaewrwergwea.com
Porta SMB	TCP 445 (exploit EternalBlue MS17-010)
Estensione file cifrati	.WNCRY
Processo figlio	tasksche.exe
Registry key	HKLM\SOFTWARE\WannaCrypt
Indirizzo Bitcoin	13AM4VW2dhxYgXeQepoHkHSQuy6NgaEb4

3.5. Remediation (Blue Team / SOC)

1. Isolare immediatamente i sistemi infetti dalla rete bloccando la porta TCP 445 a livello di firewall e switch.
2. Applicare la patch MS17-010 su tutti i sistemi Windows vulnerabili non ancora aggiornati.
3. Disabilitare SMBv1 su tutti gli host tramite PowerShell: Set-SmbServerConfiguration - EnableSMB1Protocol \$false
4. Bloccare il killswitch domain sul proxy/firewall:
www.iuqerfsodp9ifjaposdfjhgosurijfaewrwergwea.com
5. Verificare la presenza di Shadow Copy: WannaCry le elimina sistematicamente; procedere con restore da backup offline se disponibili.
6. Aggiungere lo SHA256 del campione alle blacklist degli strumenti EDR/antivirus aziendali.
7. Ricercare su tutti gli host della rete la presenza di tasksche.exe e del file @Please_Read_Me@.txt come indicatori di compromissione.
8. Monitorare la chiave di registro HKLM\SOFTWARE\WannaCrypt come indicatore di infezione attiva.
9. Attivare regole Suricata/Snort per rilevare traffico SMB anomalo e tentativi di connessione al killswitch domain.
10. Non pagare il riscatto: i server C2 di WannaCry erano già offline al momento della campagna originale e il pagamento non garantisce il recupero dei dati.

4.0 Sintesi Esecutiva

WannaCryptor è un ransomworm con score massimo (10/10 su Triage) che sfrutta l'exploit EternalBlue (MS17-010) per propagarsi autonomamente via SMB senza interazione dell'utente. Una volta in esecuzione, cifra i file con estensione .WNCRY, elimina le Shadow Copy per impedire il recovery, verifica la lingua del sistema per evitare paesi CIS e raccoglie credenziali da browser e file system.

La campagna originale del maggio 2017 ha colpito oltre 200.000 sistemi in 150 paesi in poche ore, rendendola una delle più devastanti della storia della cybersecurity. L'analisi sandbox su Triage ha confermato integralmente il comportamento atteso, con 20 tecniche MITRE ATT&CK identificate nelle categorie Execution, Persistence, Defense Evasion, Credential Access, Discovery, Collection e Impact.

Le azioni prioritarie per un Blue Team sono: isolamento immediato dei sistemi, applicazione della patch MS17-010, disabilitazione di SMBv1 e ripristino da backup offline. Il pagamento del riscatto è sconsigliato in quanto i server C2 non sono più operativi.